The Orange Book

MITS 5400G Secure Software Systems

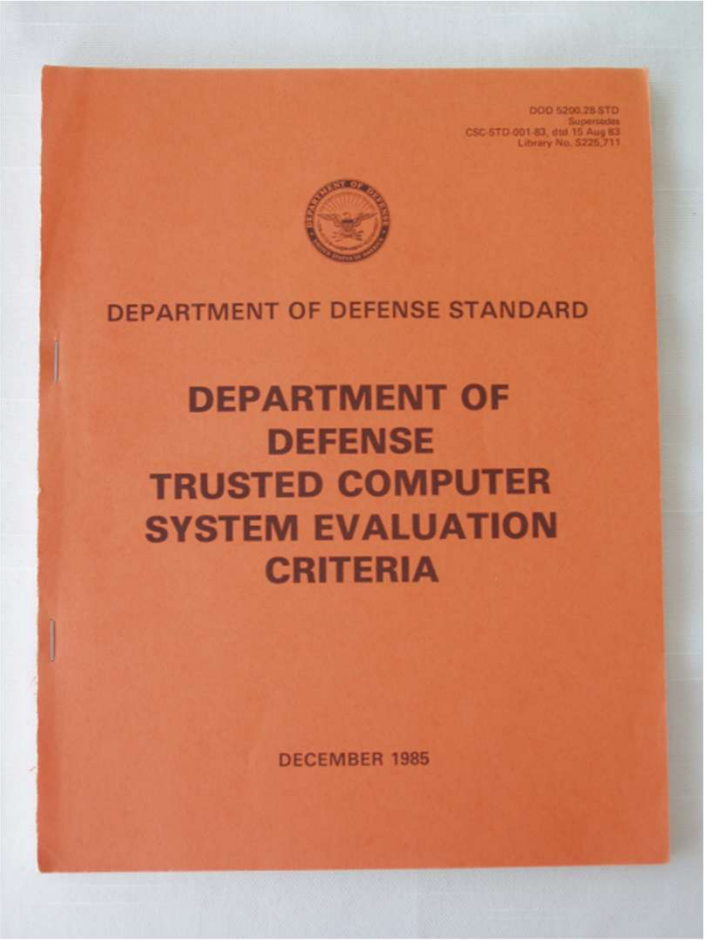
Week 1

Winter 2026

Evaluation

- The process of assembling evidence that a system meets, or fails to meet, a prescribed assurance target.

- An evaluation model done in 1985-2000 at the NSA's National Computer Security Center on computer security products proposed for U.S. government use.



The Orange Book

- The Trusted Computer Systems Evaluation Criteria – The Orange Book
- **D:** Minimal Protection - Any system that does not comply with any other category or has failed to receive a higher classification. D-level certification is very rare.
- ***C1***: Discretionary access control by groups of users. In effect, this is considered equivalent to no protection.
- ***C2***: Discretionary access control by single users; object reuse; audit.

The Orange Book (cont.)

- ***B1***: Mandatory access control. All objects carry security labels, and the security policy is enforced independently of user actions. Labelling is enforced for all input information.

- ***B2***: Structured protection. As B1, but there must also be a formal model of the security policy that has been proved consistent with security axioms. Tools must be provided for system administration and configuration management.

- ***B3***: Security domains. As B2, the Trusted Computing Base (TCB) must be minimal; it must mediate all access requests, be tamper-resistant, and be able to withstand formal analysis and testing. There must be real-time monitoring and alerting mechanisms, and a structured technique must be used in implementation.

The Orange Book (cont.)

- ***A1***: Verification design. As B3, but formal techniques must be used to prove the equivalence between the TCB specification and the security policy level.